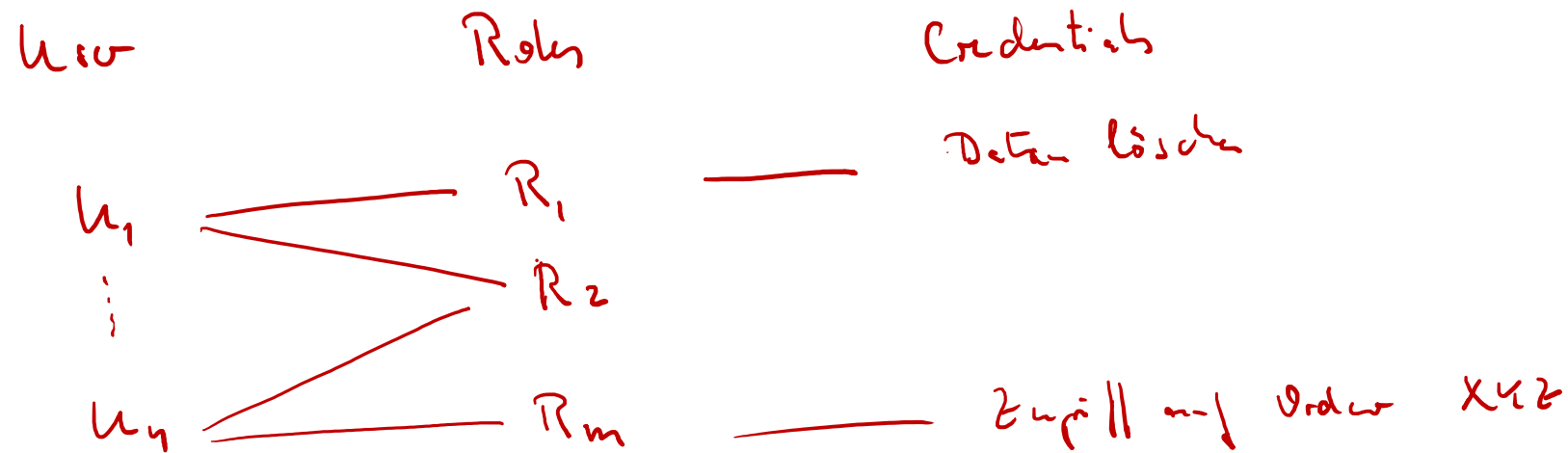


3.5 Zugriffskontrolle (Access Control)

Schutzmaßnahme: Zugriffskontrollsystem (Access Control System)

RBAC S : Role Based
A C S
4



Schutzmaßnahme: Signaturen und PKI

The diagram illustrates a secure communication process using PKI:

- CA (Certificate Authority):** Represented by a yellow box, it issues certificates. A note next to it says "allg. vertrauenswürdige Institution".
- Alice (A):** Sends a message m_A to Bob (B). The message is signed with s_A . A green box next to the signature contains $S_{k_{A,priv}}(m_A)$ and $Cert_A$.
- Bob (B):** Receives the message and verifies the signature. He then decrypts the message to get D .
- CA Request:** Alice sends a "Cert Request (A, σ_A)" to the CA.
- Keys:** Various keys are shown, including $k_{A,priv}$, $k_{A,pub}$, $k_{CA,priv}$, and $k_{CA,pub}$.
- Signatures and Verification:**
 - $s_A = S_{k_{CA,priv}}(TBS-Cert)$ is shown near the CA.
 - Verification steps are listed:
 - 1.) Check: $s = S_{k_{A,priv}}(m_A) : V_{k_{A,pub}}(m_A, s)$
 - 2.) Check das Zertifikat: $Cert_A : V_{k_{CA,pub}}(TBS-Cert, s_A)$

3.7 Verfügbarkeit (Availability)

- DoS-Angriff (Denial of Service)
- DDoS - (Distributed - " -)
- gezielter Angriff (SQL-Injection)

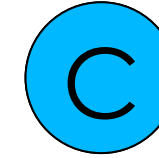
Schutzmaßnahmen:

- Zugriff möglichst einschränken
 - Firewalls, -
- sichere / robuste Implementierung

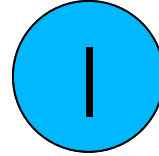
3.8 Anonymität (Anonymity)

- TOR - Netzwerk
- Internet Protokolle:
 - Elektronische Wahlen
 - " Geld

- **Vertraulichkeit** (Confidentiality, Secrecy, Privacy)



- **Integrität** (Integrity)



- **Authentizität** von Nachrichten (Message Authenticity)

- **Authentizität** von Nutzern (User Authenticity)

- **Nichtabstreitbarkeit** (Non Repudiation)

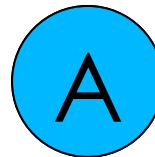
- Nichtabstreitbarkeit der **Herkunft**

- Nichtabstreitbarkeit des **Erhalts**

- **[Verbindlichkeit: Beidseitige Nichtabstreitbarkeit (?)]**

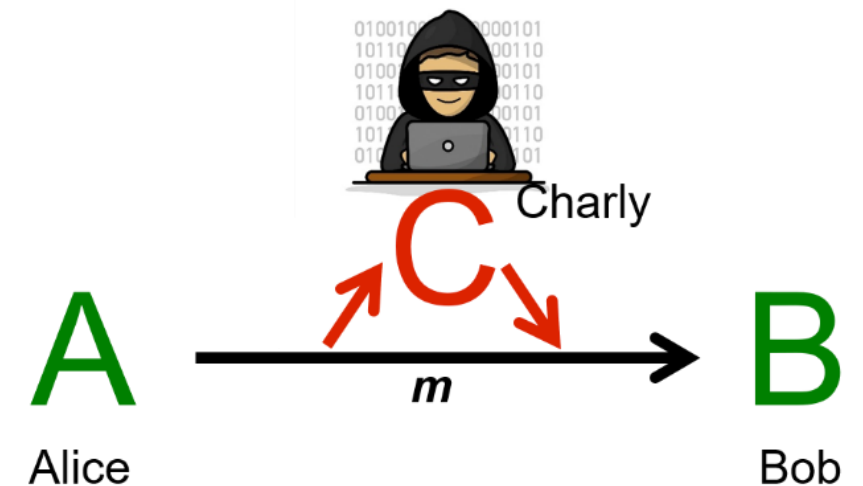
- **Autorisierung / Zugriffskontrolle** (Access Control)

- **Verfügbarkeit** (Availability)



- **Anonymität** (Anonymity)

- ...



- **Confidentiality**
- **Integrity**
- **Authenticity**
- **Non-Repudiation**
- **Access Control**
- **Availability**
- **Encryption**
- **Message Digest, MAC, Digital Signature**
- **MAC, Digital Signature**
- **Digital Signature**
- **User mgmt. systems, ACL implementations**
- **Network Filter, Firewall, Robust implementations**
- **Secure Configurations, Best Security Practices, Security awareness of users, Policies, ...**

- Kryptographisch sichere **Pseudozufallszahlengeneratoren**

Cryptographic Secure Pseudo Random Number Generators (CSPRNG)

- Kryptographische **Hashfunktionen**

Message Digests (Cryptographic Hash Functions)

} ohne Schlüssel

- **Symmetrische Verschlüsselungsverfahren** (Symmetric Ciphers)

- **Message Authentication Codes** (MACs)

}  secret key

- **Asymmetrische Verschlüsselungsverfahren** (Asymmetric Ciphers)

- **Digitale Signaturen** (Digital Signatures)

- **Schlüsselaustauschverfahren** (Key Exchange / Key Establishment)

}  private key
public key

Verschlüsselungsverfahren

4.1	Das Kerckhoffs'sche Prinzip	50
4.2	Mathematische Modellierung von Ver- schlüsselungsverfahren	51
4.3	Schlüsselaustausch	54
4.4	Angriffsszenarien	55
4.5	Brute-Force Angriffe	56
4.6	Wörterbuchangriffe (dictionary attacks)	58

4.1 Das Kerckhoffs'sche Prinzip

Kerckhoffs von Nieuwenhof (1835-1903), La cryptographie militaire 1883:

Ein sicheres Verschlüsselungsverfahren darf nicht der Geheimhaltung bedürfen und soll ohne Schaden in Feindeshand fallen können.

D. h.: Die Sicherheit eines Verschlüsselungsverfahrens sollte allein auf der Geheimhaltung des Schlüssels beruhen.

Konsequenz: Nur kryptographische Algorithmen, die im Rahmen intensiver Analysen anerkannten Kryptologen keine Schwächen offenbaren, sollten zur Anwendung kommen. (Bsp.: Wettbewerb zur Standardisierung des AES) *PQ-Algorithmus*

Vermeintliche Sicherheit durch Geheimhaltung des Verschlüsselungsalgorithmus wird auch mit **Security through obscurity** umschrieben. (Beispiele: Bruch von ursprünglich proprietären Algorithmen wie A5/1 und A5/2 (GSM), Mifare Classic, RC4 in IEEE 802.11)

4.1 Das Kerckhoffs'sche Prinzip

Kerckhoffs'sches Prinzip

Ein Verschlüsselungssystem darf nicht der Geheimhaltung bedürfen und soll ohne Schaden in Feindeshand fallen können.

Voraussetzung:

alle krypt. Algen.

Grundanforderung an Verschlüsselungsverfahren

Es soll nicht möglich sein, einen Geheimtext ohne Kenntnis des hierfür vorgesehenen Schlüssels effizient zu entschlüsseln.

Benchmark:

Brute-Force-Angriff

4.2 Mathematische Modellierung von Verschlüsselungsverfahren

Verschlüsselungsverfahren

Klartextnachrichten (plain text messages) und *Geheimtextnachrichten* (cipher text messages) sind Elemente einer Menge:

$$\mathcal{M}$$

Schlüssel sind Elemente einer als *Schlüsselraum* (key space) bezeichneten Menge:

$$\mathcal{K}$$

Ein *Verschlüsselungsverfahren* (auch *Chiffrierverfahren* (Cipher) genannt) besteht aus einem Paar von Funktionen (E, D) mit einer *Verschlüsselungsfunktion* E (E für encryption)

$$E : \mathcal{K} \times \mathcal{M} \rightarrow \mathcal{M} \quad (4.1)$$

und einer *Entschlüsselungsfunktion* D (D für decryption)

$$D : \mathcal{K} \times \mathcal{M} \rightarrow \mathcal{M} \quad (4.2)$$

$$E : \mathcal{K} \times \mathcal{M} \rightarrow \mathcal{M} \quad (4.1)$$

$$D : \mathcal{K} \times \mathcal{M} \rightarrow \mathcal{M} \quad (4.2)$$

wobei für jeden Schlüssel $k \in \mathcal{K}$ die durch

$$E_k : \mathcal{M} \rightarrow \mathcal{M}, \quad E_k(m) := E(k, m) \quad (4.3)$$

definierte Abbildung (Verschlüsselung mit dem Schlüssel k) bijektiv ist und die Umkehrfunktion $D_k := E_k^{-1}$ (Entschlüsselung mit dem Schlüssel k) durch

$$D_k : \mathcal{M} \rightarrow \mathcal{M}, \quad D_k(m) := D(k, m) \quad (4.4)$$

gegeben ist.

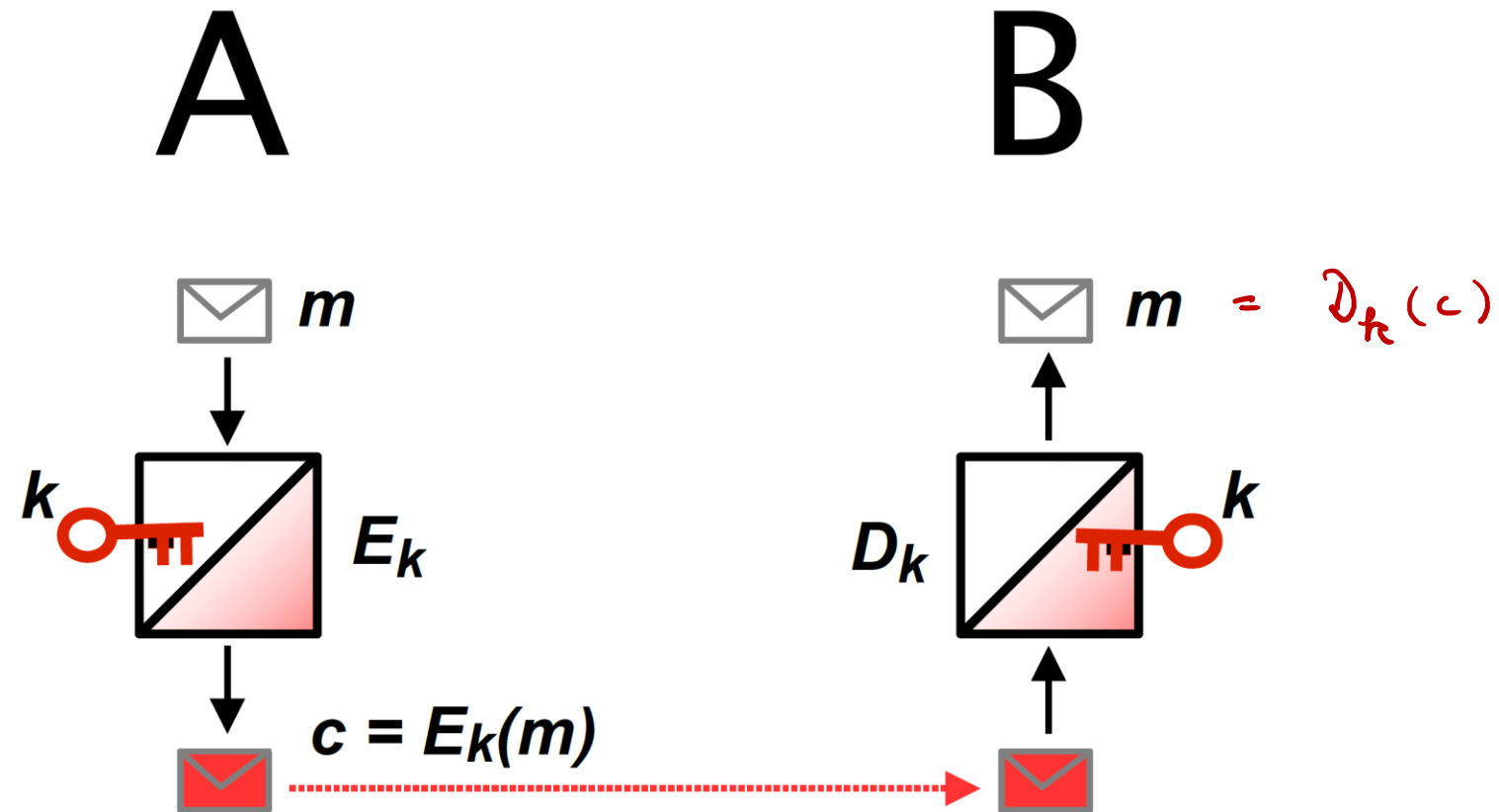


Abb. 4.2 Verschlüsselung der Klartextnachricht m mit E_k und Entschlüsselung der Geheimtextnachricht c mit D_k .

Kommentar Die Modellierung ist so allgemein gehalten, dass sie sowohl zur Beschreibung von *symmetrischen* als auch von *asymmetrischen* Verschlüsselungsverfahren geeignet ist.

$$\mathcal{K} = \{ k = (k_{\text{priv}}, k_{\text{pub}}) \mid k_{\text{priv}} \} \hat{=} \mathcal{K}_{\text{priv}}$$

$$\mathcal{K}_{\text{pub}}$$

$$\mathcal{K} \rightarrow \mathcal{K}_{\text{pub}}, \quad k \mapsto k_{\text{pub}}$$

$$E_k(m) = E_{\text{pub}}(k_{\text{pub}}, m) =: E_{k_{\text{pub}}}(m) = c$$

$$D_k(c) = D_{k_{\text{priv}}}(c) = m$$

$$E_{\text{pub}} : \mathcal{K}_{\text{pub}} \times \mathcal{M} \rightarrow \mathcal{M}$$

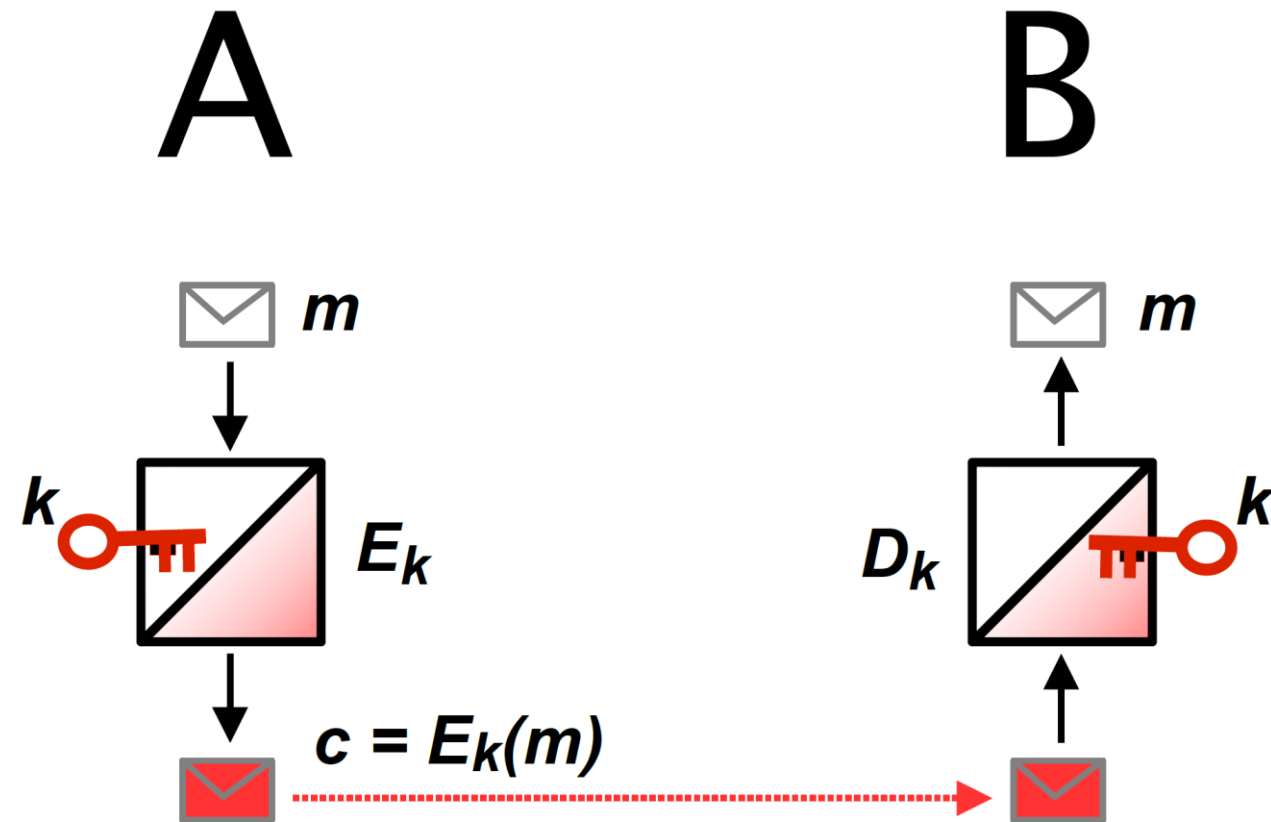


Abb. 4.2 Verschlüsselung der Klartextnachricht m mit E_k und Entschlüsselung der Geheimtextnachricht c mit D_k .

In der Praxis bestehen die Nachrichtenmengen $\mathcal{M}$ in der Regel aus endlichen Folgen (Tupeln) von Bit- oder Bytewerten, die entweder alle eine gleiche Länge besitzen, oder von beliebiger Länge sein können. D. h. mit $\mathcal{Z} = \mathbb{Z}_2$ oder $\mathcal{Z} = \mathbb{Z}_2^8$ gilt einer der folgenden Fälle:

- (i) $\mathcal{M} = \mathcal{Z}^n = \{(z_1, z_2, \dots, z_n) \mid z_i \in \mathcal{Z}\}$ für ein festes $n \in \mathbb{N}$
- (ii) $\mathcal{M} = \mathcal{Z}^{>0} := \bigcup_{n \in \mathbb{N}} \mathcal{Z}^n = \{(z_1, z_2, \dots, z_n) \mid z_i \in \mathcal{Z}, n \in \mathbb{N}\}$

Im ersten Fall wird von einem *Blockverschlüsselungsverfahren* (mit der *Blocklänge* n) gesprochen. Die Nachrichtenmengen aus (ii) treten dagegen in sogenannten *Stromverschlüsselungsverfahren* auf.

Bezeichnungen für Elemente aus $\mathbb{Z}_2^8$

Per Definition ist:

$$\mathbb{Z}_2^8 = \left\{ \begin{pmatrix} b_0 \\ b_1 \\ \vdots \\ b_7 \end{pmatrix} \mid b_i \in \mathbb{Z}_2 \right\}$$

Häufig werden Elemente aus $\mathbb{Z}_2^8$ als Bytewerte (Elemente aus $\mathbb{Z}_{256}$) notiert. Hierzu wird folgende bijektive Abbildung genutzt:

$$\begin{pmatrix} b_0 \\ b_1 \\ \vdots \\ b_7 \end{pmatrix} \mapsto \sum_{i=0}^7 b_i \cdot 2^i \quad (4.5)$$

Konkrete Bytewerte werden in der Regel als zweistellige Hexadezimalzahlen angegeben. (Auf ein vorgestelltes 0x wird im Folgenden meist verzichtet.)

Der Vektoraddition von Elementen aus $\mathbb{Z}_2^8$ entspricht die XOR-Operation von Bytewerten.

Frage 21

Geben Sie die Bytewerte an, die den Elementen

$$\begin{pmatrix} 1 \\ 1 \\ 0 \\ 0 \\ 0 \\ 0 \\ 0 \\ 0 \end{pmatrix}, \begin{pmatrix} 0 \\ 0 \\ 0 \\ 0 \\ 0 \\ 0 \\ 0 \\ 1 \end{pmatrix}, \begin{pmatrix} 0 \\ 1 \\ 1 \\ 1 \\ 1 \\ 0 \\ 0 \\ 1 \end{pmatrix} \in \mathbb{Z}_2^8$$

entsprechen.

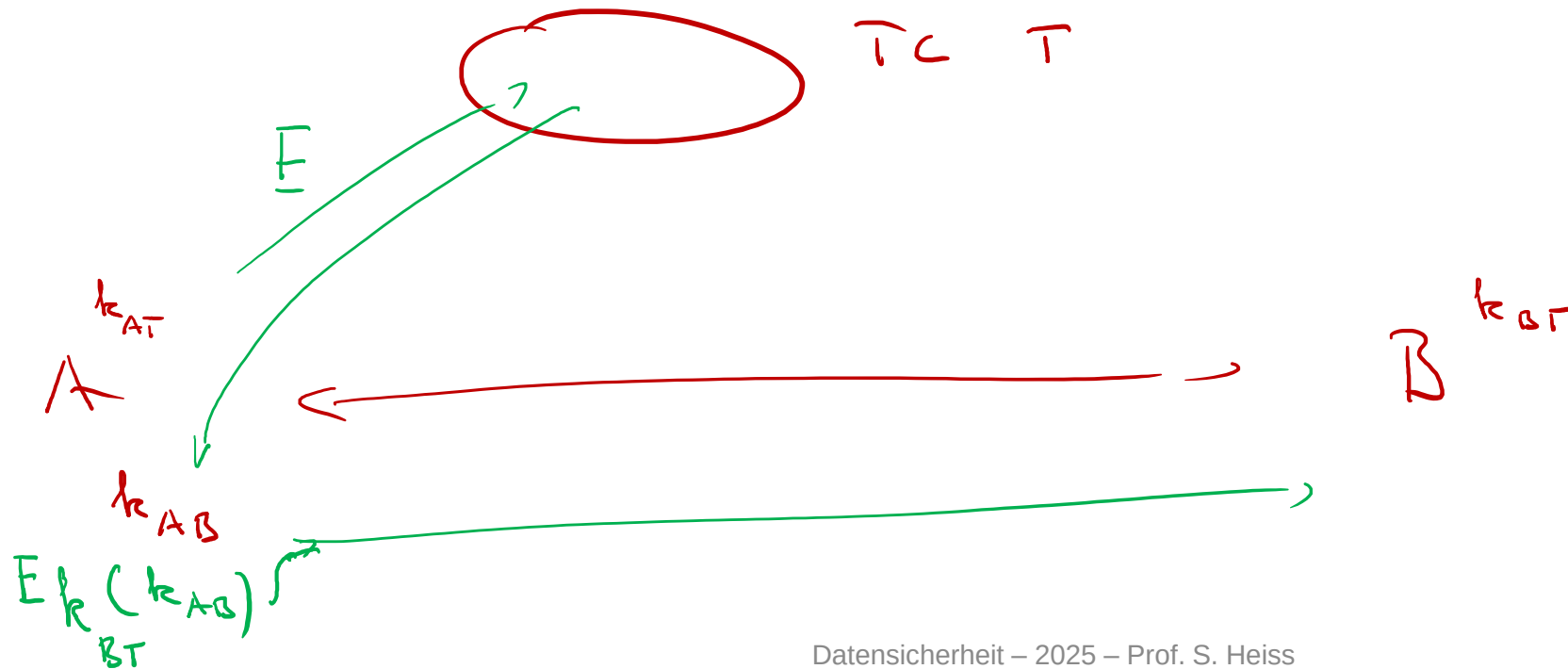
$\begin{matrix} \updownarrow \\ 3 \\ \downarrow \\ 0x03 \end{matrix}$
 $\begin{matrix} \updownarrow \\ 128 \\ \downarrow \\ 0x80 \end{matrix}$
 $\begin{matrix} \updownarrow \\ 174 \\ \downarrow \\ 0xAE \end{matrix}$

4.3 Schlüsselaustausch

Problem des Schlüsselaustausches

Bevor verschlüsselte Daten unter Verwendung eines symmetrischen Verschlüsselungsverfahrens ausgetauscht werden können, müssen die Kommunikationspartner auf vertrauenswürdige Weise in den Besitz eines gemeinsamen Schlüssels kommen.

Beispiel 4.1



4.4 Angriffsszenarien

Ciphertext-only Angriffe (known-ciphertext Angriffe)

Voraussetzung: Der Geheimtext $c = E_k(m)$ und möglicherweise weitere Geheimtexte $c_i = E_k(m_i)$ sind verfügbar.

Angriffsziel: Bestimmung von m oder (besser noch) von k .

Known-plaintext Angriffe

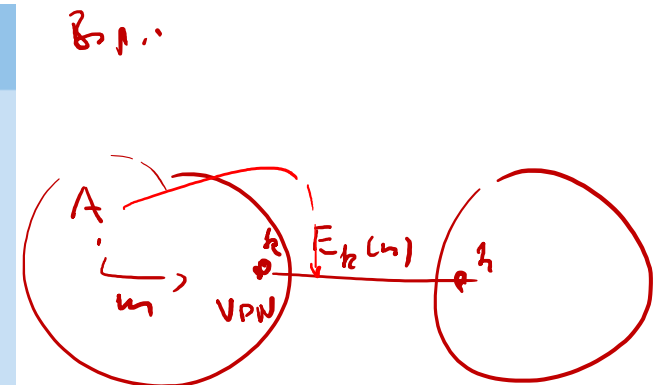
Voraussetzung: Der Geheimtext $c = E_k(m)$ und eine Reihe von Paaren $(m_i, E_k(m_i))$ sind verfügbar.

Angriffsziel: Bestimmung von m oder (besser noch) von k .

Chosen-plaintext Angriffe

Voraussetzung: Der Geheimtext $c = E_k(m)$ ist gegeben und für eine Reihe beliebig vorgegebener Klartextnachrichten m_i können die zugehörigen Geheimtextnachrichten $c_i = E_k(m_i)$ erhalten werden.

Angriffsziel: Bestimmung von m oder (besser noch) von k .



Grundanforderung an Verschlüsselungsverfahren (Version 2)

Die Durchführung eines chosen-plaintext Angriffs soll nicht effizient möglich sein.

4.5 Brute-Force Angriffe

Brute-Force Angriffe auf k

Liegen die Voraussetzungen eines known-plaintext Angriffs vor, so kann k gefunden werden, indem alle Schlüssel des Schlüsselraums durchlaufen und „ausprobiert“ werden:

Für die nach Voraussetzung vorliegenden Paare (m_i, c_i) mit $c_i = E_k(m_i)$ bezeichne $\mathcal{K}_i$ die Menge der jeweils „passenden“ Schlüssel:

$$\mathcal{K}_i := \{\tilde{k} \in \mathcal{K} \mid E_{\tilde{k}}(m_i) = c_i\}$$

Indem alle Schlüssel des Schlüsselraums einmal durchlaufen werden, ergibt sich für eine (in praktischen Anwendungen kleine und sich dynamisch beim Durchlauf ergebende) Anzahl N von Paaren $(m_i, E_k(m_i))$:

$$\bigcap_{i=1}^N \mathcal{K}_i = \{k\}$$

D. h. k ist durch die Eigenschaft bestimmt, dass k der einzige Schlüssel ist, der zu den N Klartext-Geheimtext-Paaren $(m_i, E_k(m_i))$ für $i = 1, \dots, N$ passt.

Frage 22

Sei

$$E : \mathcal{K} \times \mathcal{M} \rightarrow \mathcal{M}$$

ein Blockverschlüsselungsverfahren mit:

$$K := |\mathcal{K}| \quad \text{und} \quad M := |\mathcal{M}|$$

Betrachten Sie die Menge

$$\mathcal{E} := \{E_k \mid k \in \mathcal{K}\}$$

wie eine Menge von K zufällig gewählten Permutationen auf $\mathcal{M}$ und zeigen Sie:

- (i) Zu $m, c \in \mathcal{M}$ gibt es durchschnittlich $\frac{K}{M}$ viele Schlüssel $k \in \mathcal{K}$ mit $E_k(m) = c$.

Frage 22

Sei

$$E : \mathcal{K} \times \mathcal{M} \rightarrow \mathcal{M}$$

ein Blockverschlüsselungsverfahren mit:

$$K := |\mathcal{K}| \quad \text{und} \quad M := |\mathcal{M}|$$

Betrachten Sie die Menge

$$\mathcal{E} := \{E_k \mid k \in \mathcal{K}\}$$

wie eine Menge von K zufällig gewählten Permutationen auf $\mathcal{M}$ und zeigen Sie:

- (ii) Sind $m, c \in \mathcal{M}$ zufällig gewählt, so gibt es mit der Wahrscheinlichkeit

$$p = 1 - \left(1 - \frac{1}{M}\right)^K$$

mindestens einen Schlüssel $k \in \mathcal{K}$ mit $E_k(m) = c$.

Frage 22

Sei

$$E : \mathcal{K} \times \mathcal{M} \rightarrow \mathcal{M}$$

ein Blockverschlüsselungsverfahren mit:

$$K := |\mathcal{K}| \quad \text{und} \quad M := |\mathcal{M}|$$

Betrachten Sie die Menge

$$\mathcal{E} := \{E_k \mid k \in \mathcal{K}\}$$

wie eine Menge von K zufällig gewählten Permutationen auf $\mathcal{M}$ und zeigen Sie:

(iii) Gilt $K = M$, so gibt es zu zufällig gewählten $m, c \in \mathcal{M}$ mit der Wahrscheinlichkeit

$$p = 1 - \left(1 - \frac{1}{M}\right)^M \approx 1 - e^{-1} \approx 0,632$$

mindestens einen Schlüssel $k \in \mathcal{K}$ mit $E_k(m) = c$.

Frage 22

Sei

$$E : \mathcal{K} \times \mathcal{M} \rightarrow \mathcal{M}$$

ein Blockverschlüsselungsverfahren mit:

$$K := |\mathcal{K}| \quad \text{und} \quad M := |\mathcal{M}|$$

Betrachten Sie die Menge

$$\mathcal{E} := \{E_k \mid k \in \mathcal{K}\}$$

wie eine Menge von K zufällig gewählten Permutationen auf $\mathcal{M}$ und zeigen Sie:

- (iv) Gilt $K \ll M$, so gibt es zu zufällig gewählten $m, c \in \mathcal{M}$ mit einer Wahrscheinlichkeit p mindestens einen Schlüssel $k \in \mathcal{K}$ mit $E_k(m) = c$. Hierbei gilt:

$$p \approx 1 - e^{-\frac{K}{M}} \approx \frac{K}{M}$$

Kommentar Für den häufig vorkommenden Fall, dass alle Klartextnachrichten, die im Rahmen einer Anwendung auftreten können, Elemente einer relativ kleinen Teilmenge $\mathcal{M}_0$ der Nachrichtenmenge $\mathcal{M}$ sind, kann der Brute-Force Angriff zu einem ciphertext-only Angriff abgeändert werden, indem für die Reihe der vorliegenden Geheimentextnachrichten c_i die Mengen $\mathcal{K}_i$ nun folgendermaßen definiert werden:

$$\mathcal{K}_i := \{ \tilde{k} \in \mathcal{K} \mid D_{\tilde{k}}(c_i) \in \mathcal{M}_0 \}$$

Brute-Force Angriffe auf m

Liegen die Voraussetzungen eines chosen-plaintext Angriffs vor, so kann zu der Geheimtextnachricht $c = E_k(m)$ die zugehörige Klartextnachricht m gefunden werden, indem die möglichen Klartextnachrichten $\tilde{m} \in \mathcal{M}$ nacheinander durchlaufen und „ausprobiert“ werden, bis m gefunden ist:

$$E_k(\tilde{m}) = c = E_k(m) \quad \implies \quad \tilde{m} = m$$

D. h. m wird durch die Eigenschaft bestimmt, dass m die einzige Klartextnachricht mit $E_k(m) = c$ ist.

Grundanforderung an Verschlüsselungsverfahren (Version 3)

Die Durchführung eines chosen-plaintext Angriffs soll nicht effizient möglich sein, d. h.:

- (i) Es soll keinen Angriff auf den Schlüssel k geben, der durchschnittlich weniger als $\frac{|\mathcal{K}|}{2}$ Ver- oder Entschlüsselungsoperationen benötigt.
- (ii) Es soll keinen Angriff auf eine Klartextnachricht m geben, der durchschnittlich weniger als $\min \left\{ \frac{|\mathcal{K}|}{2}, \frac{|\mathcal{M}|}{2} \right\}$ Ver- oder Entschlüsselungsoperationen benötigt.

4.6 Wörterbuchangriffe (dictionary attacks)

m_1	c_1
m_2	c_2
$\vdots$	$\vdots$

Nonce (Number used Once)

Parameter, die bei einer wiederholten Anwendung im Rahmen eines kryptographischen Verfahrens, stets unterschiedliche Werte besitzen sollen, werden *Nonce (Number used Once)* genannt.

Typische Beispiele zur Generierung von Nonce-Werten:

- *Zähler (Counter)*, also eine ganzzahlige Variablen, die nach jeder Nutzung als Nonce-Wert inkrementiert wird.
- *Zeitstempel (Time Stamp)* mit einer hinreichend feinen Zeitauflösung.
- Zufallszahlen aus einem hinreichend großen Zahlbereich, so dass das wiederholte Auftreten einer Zahl im Rahmen der jeweiligen Anwendung mit an Sicherheit grenzender Wahrscheinlichkeit ausgeschlossen werden kann.

- Kryptographisch sichere **Pseudozufallszahlengeneratoren**
Cryptographic Secure Pseudo Random Number Generators (CSPRNG)
- Kryptographische **Hashfunktionen**
Message Digests (Cryptographic Hash Functions)
- **Symmetrische Verschlüsselungsverfahren** (Symmetric Ciphers)
- **Message Authentication Codes** (MACs)
- **Asymmetrische Verschlüsselungsverfahren** (Asymmetric Ciphers)
- **Digitale Signaturen** (Digital Signatures)
- **Schlüsselaustauschverfahren** (Key Exchange / Key Establishment)

- Security Developer's Guide
 - Java Cryptography Architecture (JCA)
 - JCA Provider (JDK Providers)
 - SUN Provider, SunRsaSign Provider
 - SunJCE Provider
 - SunJSSE Provider
 - SunPCSC Provider
 - ...

Provider der ersten Stunde

Java Cryptographic Extension

Java Secure Socket Extension (TLS)

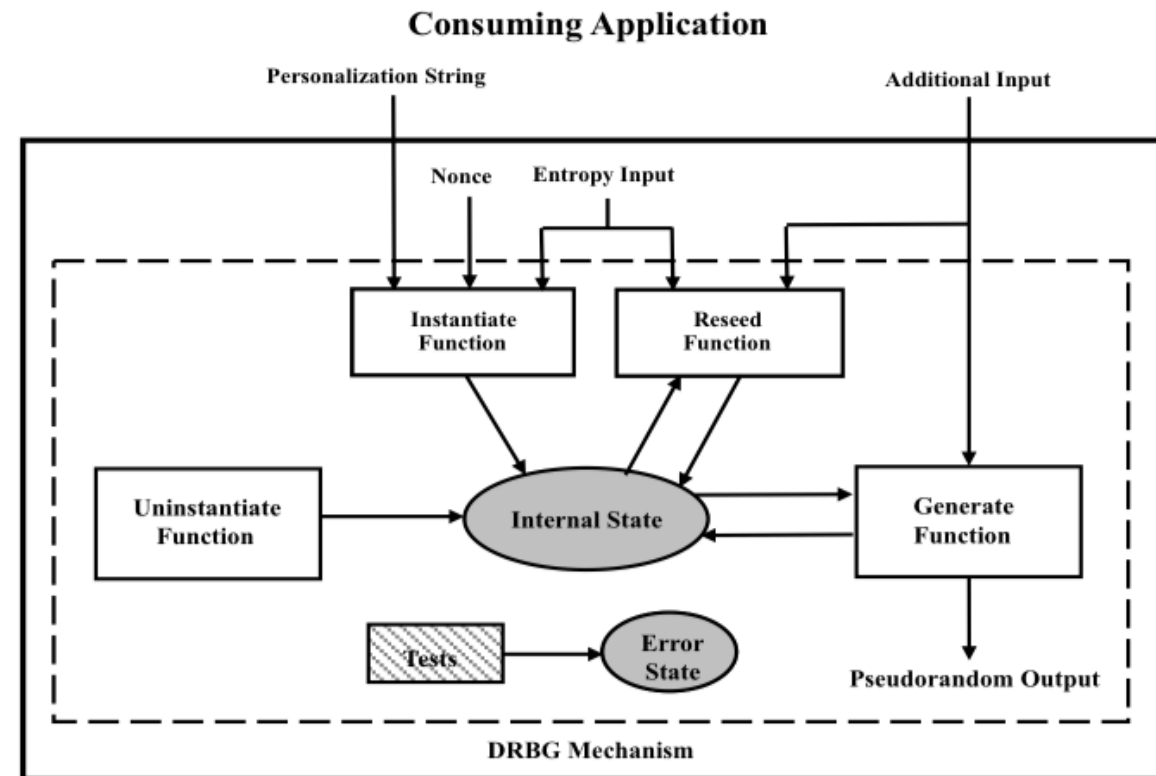
Smart Card API

- Kryptographisch sichere
Pseudozufallszahlengeneratoren
- Kryptographische **Hashfunktionen**
- **Symmet. Verschlüsselungsverfahren**
- **Message Authentication Codes**
- **Asymmet. Verschlüsselungsverfahren**
- **Digitale Signaturen**
- **Schlüsselaustauschverfahren**
- [java.security.SecureRandom](#)
- [java.security.MessageDigest](#)
- [javax.crypto.Cipher](#)
- [javax.crypto.Mac](#)
- [javax.crypto.Cipher](#)
- [java.security.Signature](#)
- [javax.crypto.KeyAgreement](#)

- JCA -Implementierungen: SecureRandom
- Recommendation for Random Number Generation Using Deterministic Random Bit Generators, NIST Special Publication 800-90A, June 2015

<http://dx.doi.org/10.6028/NIST.SP.800-90Ar1>

- DRBG Functional Model:



- Üblicherweise basieren diese auf linearen Kongruenzgeneratoren (die einmalig mit einem Seed-Wert initialisiert werden.)

$$x_0 = \text{Seed}$$

$$x_{i+1} = (a \cdot x_i + b) \bmod c$$

- Üblicherweise basieren diese auf linearen Kongruenzgeneratoren (die einmalig mit einem Seed-Wert initialisiert werden.)
- Beispiel: Java's Random-Klasse implementiert einen PRNG auf Grundlage des linearen Kongruenzgenerators:

```
39  
40 public static long nextSeed(long seed) {  
41     return (seed * 0x5DEECE66DL + 0xBL) & ((1L << 48) - 1);  
42 }
```

$x_{i+1} = x_i \cdot a + b (= 11) \mod c \quad (c = 2^{48})$

- $x_{n+1} = (25214903917 \cdot x_n + 11) \mod 2^{48}$
- Nur die höchsten 32 Bit (d. h. `(int) (seed >>> 16)`) werden in Rückgabewerten (z. B. von nextInt()) genutzt.

[< Zurück zum Test](#) **Frage** [Statistik](#)

Frage bearbeiten

Seite bearbeiten

Vorschau zurücksetzen

Random-OTP

Alice hat eine Nachricht m mit einem One-Time-Pad (OTP) verschlüsselt.

Die Nachricht m besteht aus einer Folge von ASCII-Zeichen, die einen lesbaren Text darstellen.

Leider hat Alice an der LV Datensicherheit nicht teilgenommen und das OTP mit folgender Methode erzeugt:

```
public static byte[] getTimePad(int byteLength) {  
    byte[] otp = new byte[byteLength];  
  
    Random prng = new Random();  
    prng.nextBytes(otp);  
    return otp;  
}
```

Charly konnte den Geheimtext c abfangen. Der Hexstring von c ist:

c : **AEE8FDA24A4EC4B81D80B42BD0E78AF3ED6141D5EC85987B7408FFB895794090E96A54F3BC29061EF7**

Außerdem weiß Charly, dass der zu m gehörige Klartext mit **Hallo Bob** beginnt.

Wie lautet der gesamte zu m gehörige Klartext?